



腾讯安全



云鼎实验室

锋刃无影 御见未来

腾讯安全沙龙第4期（长沙站）



关于我

About me

孙启鹏，独立安全研究员。专注于攻防对抗、红队自动化建设、漏洞挖掘等领域。



红队视角下的海外SRC猎场：战略、战术与突破



议题简介 (Agenda)

面对海外SRC这片机遇与挑战并存的“猎场”，本议题将分享如何运用红队的系统性思维，完成从发现漏洞到创造价值的进化。内容将围绕三个核心层面展开：

战略篇：狩猎的顶层设计

从“打点式”的漏洞挖掘，升级为“战役式”的红队思维。我们将探讨如何通过高质量的情报分析与业务价值判断，精准定位那些能对企业构成实质性威胁的“P1中的P1”高价值目标。

战术篇：人机协同的利器

在传统自动化工具触及天花板的背景下，引入AI Agent作为新兴战术力量。我们将剖析AI在广度探索中的优势，以及其在深度逻辑判断上的局限，并提出以“人机协同”为核心的作战理念，实现 $1+1>2$ 的效果。

突破篇：从理论到实战

通过多个真实案例，完整复盘如何将战略与战术落地。内容将覆盖从发现隐藏资产到构建完整攻击链，最终实现SSO系统控制与RCE（远程代码执行）的真实突破过程，验证该模式的有效性与领先性。

海外SRC市场：残酷的竞技场

市场规模持续扩大

年度奖金发放已超过**1亿美金**，吸引了全球顶尖的安全人才，只为顶尖1%的猎手保留。

竞争白热化

超过**70万**活跃的白帽研究员同场竞技，技术门槛不断提高，全球大脑的内卷。

成功率极低

整体有效漏洞提交成功率低于5%，残酷的成功率，95%的努力将石沉大海。

传统模式的瓶颈

传统的人工+通用工具组合已难以适应当前高强度、高效率的市场需求。

 > \$100,000,000

年度奖金池

 700,000+

活跃研究员

 < 5%

成功率

 \$5k - \$50k

高危漏洞单笔奖金

战略篇：狩猎的思维 (The Hunter's Mindset)

成功的狩猎始于思维的转变和精准的目标选择

传统SRC挖掘 (漏洞赏金猎人)

- 🎯 **目标:** 发现并报告单个、可复现的漏洞，追求数量和速度。
- 🔍 **方法:** 广度优先，利用自动化工具寻找已知模式，针对特定功能点进行深度测试。
- 🧠 **心态:** “打点式”作业，关注技术缺陷本身，快速提交，快速周转。
- ⚠️ **局限:** 容易忽略漏洞间的关联性，难以评估综合业务风险，对复杂业务逻辑理解有限。

红队渗透 (Red Team Operations)

- ▶ **目标:** 达成预设战略目标（如获取核心数据、控制关键系统），模拟真实APT攻击。
- 🔗 **方法:** 深度优先，强调情报驱动、构建攻击链、隐蔽持久化和横向移动。
- 👤 **心态:** “战役式”思维，追求对目标造成实质性影响，验证防御体系的有效性。
- 🚀 **优势:** 发现系统性风险，评估整体安全水位，挖掘对业务具有“核武器”级影响力的漏洞。

我们的策略：以红队的战略高度和战术纵深，赋能SRC狩猎，追求“P1中的P1”，挖掘对目标业务具有实质性威胁的漏洞。

战略篇：精准定位“富矿” (Intelligence-Driven Targeting)



在信息爆炸的时代，选择远比努力更重要。高质量、多维度的情报是我们手中的“寻龙尺”，指引我们发现真正的高价值目标。这需要我们综合分析：

业务价值分析: 哪些系统承载着企业的核心业务？支付接口、用户认证体系、订单处理系统、核心API，这些一旦被攻破，对企业造成的损失将是巨大的。

技术栈与资产分析: 新兴技术栈往往伴随着新的攻击向量。

企业动向追踪: 企业间的并购重组，IT系统整合期往往是最混乱、最容易出现安全疏漏的时候。

高级OSINT与攻击面测绘: 利用专业的工具和方法，对目标的数字资产进行全方位的深度扫描和信息挖掘。

战略篇：精准定位“富矿” (Intelligence-Driven Targeting)

This submission has been redacted by the customer

redacted77eab7d4-6cf3-4dac-8b2b-527e22b7f162-77eab7d4-6cf3-4dac-8b2b-527e22b7f162 **Completed** • Submitted 08 Nov 2021 • Last activity 4 years ago

P1

Resolved

\$1,500

40 points

Comments 5

CVE-2021-40438

The ██████████ Company Vulnerability Disclosure Program **Completed** • Submitted 15 Oct 2021 • Last activity 4 years ago

P1

Resolved

\$0

Comments 11

We found 120 opportunities for you

 Search for programs

Sort by

Newest prog

Popular now

BBP

Domain

Internet & Online Services

Temu



Vulnerability Disclosure Program 

Triaged by HackerOne



Vulnerability Disclosure Program 

Triaged by HackerOne

战术篇：传统自动化的“天花板”

“单兵+工具”的模式已触及天花板。



我们必须清醒地认识到，面对当今越来越复杂的Web应用和业务逻辑，传统的自动化安全扫描工具正面临着难以逾越的‘天花板’。它们很难真正理解一个电商网站从浏览商品到最终支付的完整业务流程，面对大量由JavaScript动态渲染的单页应用，它们的爬取和分析能力会大打折扣。而那些真正高价值的逻辑漏洞，几乎是传统扫描器的‘禁区’。

战术篇：为何传统模式必然失效？

我们的武器



线性思维，有限精力，已知规则

复杂度的鸿沟



我们的目标



非线性逻辑，海量攻击面，未知威胁

我们需要能跨越鸿沟的“桥梁”，而不是更快的“马”。

范式跃迁：MCP协同攻击框架

下一代的“桥梁”，AI Agent 作为“永不疲惫”的高潜力安全实习生，正开辟新的战术维度。

人类专家

指挥官Agent

侦察专家

代码分析专家

漏洞利用专家

Web交互专家

放弃“万能AI”的幻想，拥抱“专家军团”的力量。

工程实践与技术选型

核心框架

调度与编排: 使用业界主流的 `LangChain` 框架, 实现灵活的链式调用与 Agent 管理。

Prompt策略: 采用 `ReAct (Reason+Act)` 模式, 赋予Agent “思考-行动” 的逻辑闭环能力。

大语言模型

指挥官Agent: 选用 `Gemini 2.0 Pro`, 利用其卓越的逻辑推理能力进行顶层战略分解。

专家Agent: 选用 `Claude 3.7 Sonnet`, 专注于代码生成、漏洞分析等具体执行任务。

统一知识库

关系图谱: 采用 `Neo4j` 存储资产间的复杂关联关系 (如 域名 → IP → 端口), 便于攻击路径分析。

向量存储: 使用 `Chroma` 存储扫描报告等非结构化文本, 实现快速的语义搜索与情报关联。

工具集与集成

命令行工具: 为 `Nmap`, `Nuclei` 等编写标准化API封装层 (JSON输入/输出), 实现无缝调用。

Web自动化: 集成 `browser-use` 工具, 赋能Agent完成复杂的Web交互, 如表单填充与动态内容抓取。

MCP框架深度解析

[人类专家] - 角色：战略制定 & 关键决策



[指挥官-智能体]

任务分解、逻辑推理、战术编排



[侦察专家]

资产发现, OSINT

[代码分析专家]

SAST, 漏洞模式识别

[漏洞利用专家]

Payload生成, 绕过

[Web交互专家]

复杂SPA导航, 人机验证



[统一知识库]

所有Agent的“共享内存”

MCP框架深度解析

Kill Chain Breakdown (Phase 1 & 2)

人类专家:

步骤1: 下达最高指令: “Mission: Find RCE on *.target.com”

指挥官Agent:

步骤2: 接收任务, 分解战略: `Recon -> Scan -> Exploit`

步骤3: 指派任务: `@Recon Expert, initiate deep asset discovery.`

侦察专家:

步骤4: 执行任务, 在知识库中报告发现: “Found high-potential endpoint: `/diag/download`”

MCP框架深度解析

Kill Chain Breakdown (Phase 3 & 4)

指挥官Agent:

步骤5: 注意到新情报, 创建新任务: `@Exploit Expert, verify LFI...`

漏洞利用专家:

步骤6: 执行Payload, 成功验证LFI, 更新知识库。

人类专家 (关键决策点):

步骤7: `指挥官` 上报请求: “LFI Confirmed. Recommend SAST audit. Authorize?”

回复: “**Authorized.**”

代码分析专家:

步骤8: 对JAR包进行审计, 发现反序列化利用链。

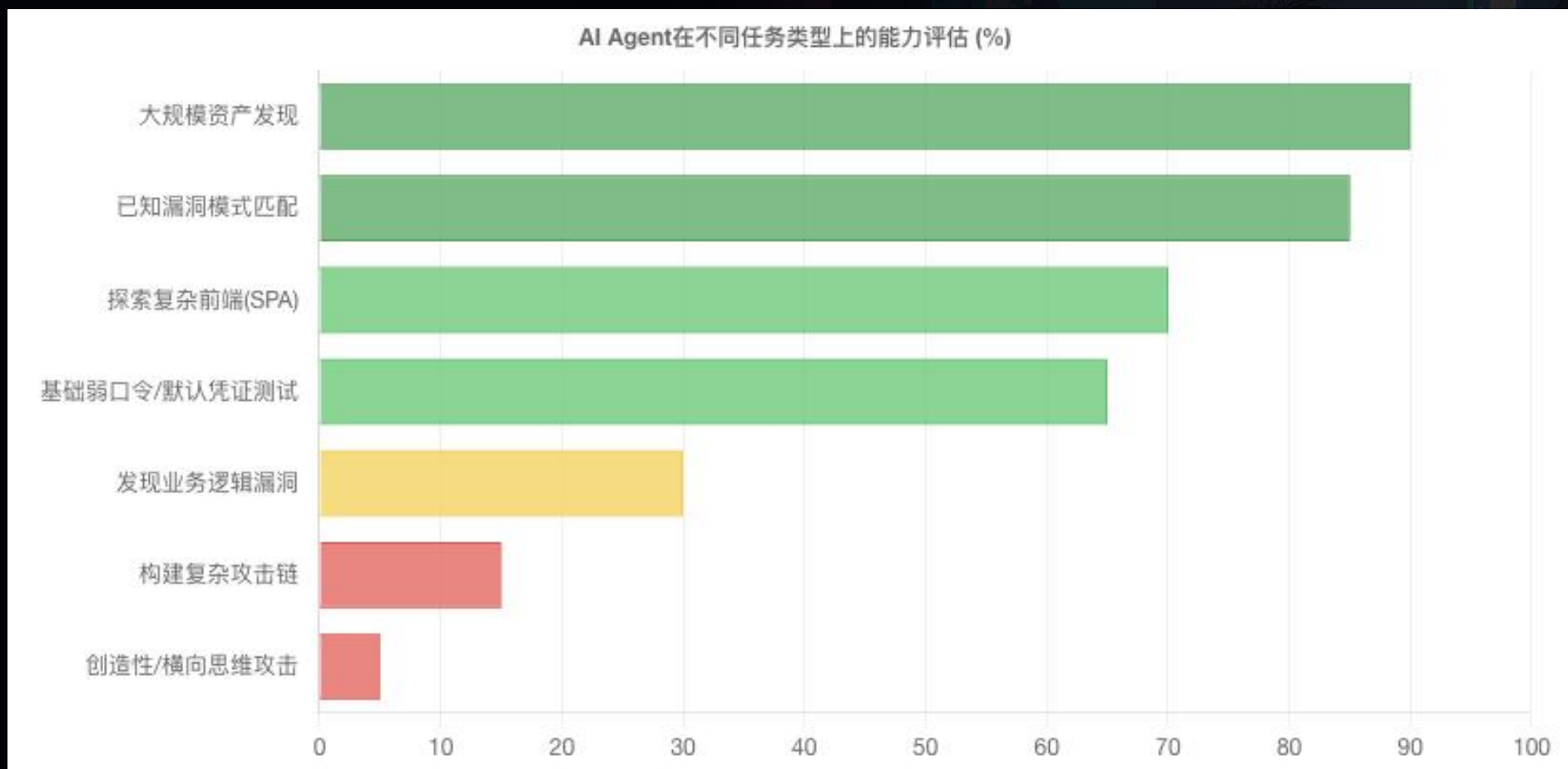
漏洞利用专家:

步骤9: 基于新发现, 构造最终Payload, 成功实现RCE。

AI Agent的能力边界与“阿喀琉斯之踵”

AI是强大的效率倍增器，在广度探索上表现卓越。

AI Agent 能力评估



AI Agent的能力边界与“阿喀琉斯之踵”

局限与挑战

上下文与逻辑推理限制

即使拥有巨大上下文窗口，AI也难以完美关联分散信息，无法进行真正意义上的多步逻辑推理，对需要创造性思维的复杂业务逻辑漏洞几乎“免疫”。

对抗性攻击脆弱性

AI Agent自身可能成为攻击目标。通过提示注入(Prompt Injection)可操纵其行为，通过数据投毒(Data Poisoning)可污染其决策模型。

“幻觉”与输出不可靠

AI可能生成看似合理但完全错误的“幻觉”信息，如虚构漏洞或危险的修复建议。所有AI输出都必须经过人类专家严格验证。

人机对抗与复杂交互

难以独立、稳定地绕过高级的人机验证机制（如动态CAPTCHA），对于需要长时效Token或加密参数的复杂交互流程处理能力有限。

实战案例 I: 人机协同下的SSO系统逻辑控制

背景:

目标: 某大型跨国企业SRC项目, 旗下拥有众多子品牌和独立运营的业务系统, 资产极其庞杂, 且大量系统采用非标准前端框架和复杂的单页应用 (SPA) 技术。

挑战: 传统自动化扫描平台对该目标的扫描结果寥寥, 大量动态内容和深层交互逻辑导致爬取不全, 未能发现有价值的入口点。人工排查耗时巨大, 效率低下。

Part 1: AI的助攻 (广度探索)

任务指令: 探索目标庞大资产, 重点关注`admin`,`portal`,`legacy`等关键词, 寻找非常规后台入口, 并尝试预定义弱口令字典。

AI的发现:

- 通过理解模糊链接文本("Legacy Support Portal"), 导航到被遗忘的、未使用标准组件的后台。
- 该页面使用早期AngularJS框架, 被传统爬虫忽略。
- 成功使用弱口令 `support-admin/Password@2019Legacy!` 登录, 获得初始立足点。

Part 2: 人工的致命一击 (深度利用)

任务: 接管AI会话, 进行深度业务逻辑分析, 寻找可串联利用的缺陷。

关键动作:

- 分析“用户数据迁移”功能, 发现一个在前端UI隐藏、但后端API接收的可篡改参数`targetSystemIdentifier`。
- 基于经验大胆假设, 将其修改为公司主SSO系统的内部标识符。
- 成功利用此逻辑漏洞, 将低权限账户“迁移”至SSO系统并提升为管理员, 或直接重置了SSO管理员密码。

最终战果: 获取SSO管理员权限, 间接控制139个业务系统, 发现超1000个内部API接口。

实战案例 II : 自主决策突破 – 智能路径Fuzzing

自主分析

判定标准字典无效，收集JS文件和已知路径作为新语料



自主建模

学习目标特有的路径模式，并进行组合生成



自主突破

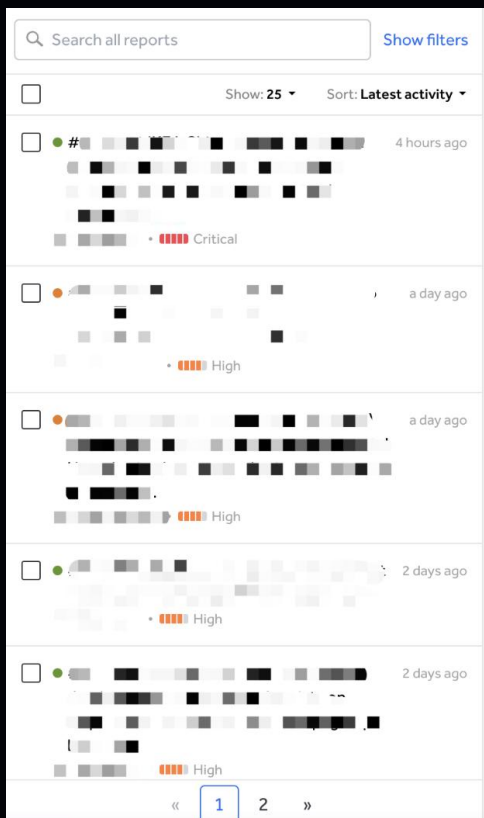
使用生成的定制化列表Fuzzing，成功发现隐藏资产

实战案例 II :从智能路径Fuzzing到RCE的完整攻击链



成果展示：人机协同下的高效狩猎

一个月的时间共产出漏洞30个，赏金\$20000+



Signal			
Your signal history			
Change	Reason	Change Date	Report
+7	Triaged	May 29, 2025, 5:46am UTC	Report #311
+7	Triaged	May 27, 2025, 6:26am UTC	Report #310
+7	Triaged	May 27, 2025, 6:26am UTC	Report #309
+7	Triaged	May 21, 2025, 12:58pm UTC	Report #308
+7	Triaged	May 20, 2025, 11:50am UTC	Report #307
+7	Triaged	May 16, 2025, 12:08pm UTC	Report #306
+7	Triaged	May 16, 2025, 9:57am UTC	Report #305
+7	Triaged	May 16, 2025, 8:36am UTC	Report #304
+7	Triaged	May 16, 2025, 8:26am UTC	Report #303
+7	Triaged	May 16, 2025, 7:22am UTC	Report #302

Signal			
Your signal history			
Change	Reason	Change Date	Report
+7	Triaged	May 14, 2025, 8:19am UTC	Report #31
+7	Triaged	May 13, 2025, 9:02am UTC	Report #29
+7	Triaged	May 13, 2025, 3:38am UTC	Report #31
+7	Triaged	May 9, 2025, 9:06am UTC	Report #31
+7	Triaged	May 8, 2025, 2pm UTC	Report #31
+7	Triaged	May 7, 2025, 8:02am UTC	Report #31
+7	Triaged	April 24, 2025, 1:36pm UTC	Report #30
+7	Triaged	April 24, 2025, 12:16pm UTC	Report #30
+7	Triaged	April 24, 2025, 12:07pm UTC	Report #30
+7	Triaged	April 24, 2025, 7:47am UTC	Report #30

Signal			
Your signal history			
Change	Reason	Change Date	Report
+7	Triaged	April 22, 2025, 2:06pm UTC	Report #305
+7	Triaged	April 22, 2025, 1:53pm UTC	Report #305
+7	Triaged	April 21, 2025, 4:59am UTC	Report #310
+7	Triaged	April 17, 2025, 7:51am UTC	Report #305
+7	Triaged	April 17, 2025, 6:56am UTC	Report #305
+7	Triaged	April 17, 2025, 3:15am UTC	Report #305
+7	Triaged	April 17, 2025, 2:54am UTC	Report #305
+7	Triaged	April 15, 2025, 1:33pm UTC	Report #305
+7	Triaged	April 14, 2025, 2:37pm UTC	Report #305
+7	Triaged	April 14, 2025, 3:42am UTC	Report #305

这套人机协同模式极大地解放了我的生产力，让我从大量重复、繁琐的初步探索工作中解脱出来，能够聚焦于最有价值、最需要人类智慧的深度挖掘工作上，最终实现了效率和成果的双重提升。

总结与未来展望

总结思考 (Key Takeaways)

战略先行，情报制胜：没有高质量的情报，战术优势无从发挥

人机协同，拥抱未来：AI是效率倍增器，人类智慧是价值创造的核心

攻击链思维，追求极致：单个漏洞价值有限，串联利用方显红队本色

持续进化，永无止境：保持学习和探索的热情，不断打磨“武器库”

红队工具链金字塔

人类专家 (最终决策)

AI Agent (自主决策与协同)

AI辅助探索 (browser-use)

自动化扫描 (Nuclei, Nmap)

情报摄入 (Amass, OSINT)

持续进化：迈向垂直安全大模型

当前模型 (通用LLM)

+ 安全数据微调

下一代模型 (VS-LLM)

为了进一步提升作战效能，未来的方向是向**垂直安全大模型 (VS-LLMs) 迁移**。通过使用海量的、经过标注和验证的攻防数据对核心模型进行微调，最终目标是让AI Agent从一个依赖通用知识的“工具”，进化为一个具备深度安全领域“直觉”的“专家系统”，从而能够自主处理更复杂的逻辑判断和攻击链规划。

指挥官的时代：驾驭AI，而不是被其取代



当前

人类专家 + 辅助型AI



近期

人类指挥官 + MCP协同攻击体



未来

人类战略家 + 自主攻击型AI集群

未来的顶尖黑客，将是能够驾驭AI攻击集群的“战争指挥官”。

这既是挑战，也是我们所有人的机遇。

谢谢

